

Cyber Security Policy

A **cyber security policy** is a **set of rules, guidelines, and procedures** used by an organization to protect its data, systems, and network from cyber attacks. It defines **what is allowed, what is restricted, and how security should be maintained**.

Main goal:

1. Protect **Confidentiality**
2. Maintain **Integrity**
3. Ensure **Availability**
4. Follow laws and compliance

Cyber security policy - ESSP, ISSP, SYSSP

➤ Enterprise Security System Policy

This is the **highest-level policy** in an organization.
It is created by **top management**.

Purpose

- Defines overall security goals
- Sets security responsibilities
- Creates rules for all employees
- Supports company mission and vision
- Defines punishment for violations

Example

- All company data must be protected
- Passwords must be changed every 60 days
- Employees must not share confidential files

Features

- Broad and strategic
- Applies to whole organization
- Long-term policy
- Executive level document

➤ ISSP (Issue-Specific Security Policy)

This policy focuses on **specific issues or technologies**.

Purpose

It handles one particular security topic.

Examples

- Email usage policy
- Internet usage policy
- Social media policy
- Mobile phone policy
- BYOD (Bring Your Own Device)
- Cloud access rules

Features

- Specific and focused
- Updated frequently
- Solves new security issues
- Easier to modify than ESSP

➤ SYSSP (System-Specific Security Policy)

This policy focuses on **specific systems, devices, and technical configurations**.

Purpose

Provides technical instructions for system security.

Examples

- Firewall configuration
- Server access control
- Router settings
- Antivirus installation
- Database permissions

Features

- Technical policy
- Used by administrators
- Device and system level
- More detailed than ISSP

Control Strategies in Cyber Security

Control strategies are the **methods used to reduce cyber risks**.

Types of Control Strategies

1) Preventive Controls

Stop attacks **before they happen**.

- Firewall
- Antivirus
- Passwords
- MFA
- Access control

2) Detective Controls

Find attacks **when they happen**.

- IDS
- Log monitoring
- CCTV
- Intrusion detection

3) Corrective Controls

Fix the problem **after attack**.

- Backup restore
- Patch updates
- Malware removal

4) Deterrent Controls

Discourage attackers.

- Warning banners
- Security awareness
- Legal notices

5) Recovery Controls

Bring system back to normal.

- Disaster recovery
- Backup recovery
- Business continuity

Protection Mechanisms

Protection mechanisms are **tools and techniques used to enforce security policies**.

Important Protection Mechanisms

- **Authentication** → verifies user identity
- **Authorization** → gives access permissions
- **Encryption** → protects data
- **Firewall** → blocks unauthorized traffic
- **IDS/IPS** → detects and prevents intrusion
- **Backup systems** → data recovery
- **Antivirus** → malware protection
- **Digital signatures** → ensures authenticity
- **Biometric security** → fingerprint, face lock

Cryptography for Security

Cryptography means **converting readable data into secret coded form** so only authorized users can read it.

Goals of Cryptography

- Confidentiality
- Integrity
- Authentication
- Non-repudiation

Types of Cryptography

1) Symmetric Key Encryption : Same key is used for encryption and decryption.

Example

- AES
- DES

Fast and secure for large data

2) Asymmetric Key Encryption

Uses **two keys**

- **Public key** : Public key is used only for the purpose of encrypting the data.
- **Private key** : Private key is used for both encrypting and decrypting the sensitive data. It is shared between the sender and receiver of encrypted data.

Example

- RSA
- ECC
- Used in digital signatures and secure communication

3) Hashing :Converts data into fixed-size hash value.

Example

- SHA-256
- MD5
- Used for password storage